

Vulnerability Register — MediConnect

Summary

Severity	Count	Remediated	Accepted Risk
Critical	4	4 (Remediated)	0
High	1	1 (Remediated)	0
Medium	3	1 (Remediated)	2 (Documented)
Low	2	0	2 (Documented)
Total	10	6	4

Critical Findings

AS-01 — Chat History IDOR (PHI Exposure)

Field	Value
Finding ID	AS-01
Title	Insecure Direct Object Reference in Chat History API
Affected Component	<code>GET /api/chat/history/room/:roomId</code> — chatController.js
Severity	Critical
Likelihood	High — requires only authentication + guessing room ID format
Security Impact	Full read access to any patient-doctor conversation
Business Impact	HIPAA breach — unauthorized disclosure of PHI (medical symptoms, SSN)
Preconditions	Valid JWT token (any role)
OWASP Category	A01:2021 — Broken Access Control
HIPAA Control	§164.312(a)(1) — Access Control

Root Cause: The endpoint accepted any `roomId` parameter without verifying the requesting user was a participant in that chat room.

Evidence (Before):

- Patient B (userId=2) sent `GET /api/chat/history/room/1-3`
- Response: `200 OK` with Patient A's message: "Doctor, I have severe chest pains and my SSN is 123-45-6789"

Remediation:

```
+ const [idA, idB] = roomId.split('-').map(Number);
+ if (userId !== idA && userId !== idB) {
+   return res.status(403).json({ message: 'Access denied' });
+ }
```

Retest Result: `403 Forbidden` — "Access denied: you are not a participant in this chat" (Verified)

Status: Remediated and Retested

AS-03 — Prescription IDOR (Patient Safety)

Field	Value
Finding ID	AS-03
Title	Any User Can Terminate Any Prescription
Affected Component	<code>PUT /api/prescriptions/end/:id</code> — <code>prescriptionController.js</code>
Severity	Critical
Security Impact	Unauthorized modification of medical records
Business Impact	Patient safety risk — medication prematurely terminated
OWASP Category	A01:2021 — Broken Access Control
HIPAA Control	§164.312(c)(1) — Integrity

Evidence (Before): Patient B sent `PUT /api/prescriptions/end/1` → `200 OK`

Remediation: Added doctor ownership verification via `doctor_id` column check.

Retest Result: `403 Forbidden` (Verified)

Status: Remediated and Retested

AS-04 — Unread Messages IDOR

Field	Value
Finding ID	AS-04
Title	Unread Message Count Exposes Other Users' Chat Activity
Affected Component	GET /api/chat/unread?userId=X — chatController.js
Severity	Critical
Security Impact	Communication pattern metadata leaked
OWASP Category	A01:2021 — Broken Access Control

Root Cause: Server used `req.query.userId` instead of `req.user.userId`.

Evidence (Before): Patient B queried `?userId=3` → received `{"1-3":1}` (Doctor's data).

Retest Result: Returns `{}` (Patient B's own data only) (Verified)

Status: Remediated and Retested

AS-06 — Admin Self-Registration (Privilege Escalation)

Field	Value
Finding ID	AS-06
Title	Anyone Can Register as Admin and Access All PHI
Affected Component	POST /api/auth/register — authController.js
Severity	Critical
Security Impact	Full admin access: read all patients, doctors; delete users
Business Impact	Complete system compromise — mass PHI exposure
OWASP Category	A01:2021 — Broken Access Control
HIPAA Control	§164.308(a)(4) — Information Access Management

Evidence (Before): Sent `{"role":"admin"}` → 201 Created → GET /api/admin/patients returned all PHI.

Remediation: Removed `'admin'` from `validRoles`. Only `['patient', 'doctor']` allowed.

Retest Result: 400 Bad Request (Verified)

Status: Remediated and Retested

High Findings

AS-05 — Missing Role Middleware on Prescription Routes

Field	Value
Finding ID	AS-05
Severity	High
Description	Prescription routes lacked <code>authorizeRoles()</code> middleware
Remediation	Added role-based middleware to all prescription routes
Status	Remediated

Medium Findings

AS-07 — No Token Revocation on Logout

Severity: Medium | **Status:** Accepted Risk — mitigated by HttpOnly cookies + 24h expiry

AS-08 — No Rate Limiting on Login

Severity: Medium | **Status:** Partially Mitigated — brute-force detection alert implemented

SG-01 — Missing CSRF Protection

Severity: Medium | **Source:** Semgrep | **Status:** Accepted Risk — SameSite=Lax cookies

Low Findings

SG-02 — TLS Verification Bypass in DB Config

Severity: Low | **Source:** Semgrep | **Status:** Development environment only

DEP-01 — Vulnerable Dependencies

Severity: Low–High (mixed) | **Source:** npm audit (92 total) | **Status:** Future Work